

Leon Project — Audit & Debug Pass

Repository: royalindustry94-crypto/HumanGate | Scope: Android overlay companion (main) + voice work on claude/leon-voice-conversation @ 36961d6 | Date: 2026-09-24

Four-part audit of the whole Leon project. No PR was opened and nothing was merged or approved. The two verified fixes were committed to the working branch copilot/claudeleon-audit-debug; claude/leon-voice-conversation (the active Builder's lane) and main were left untouched per the repo's one-Builder-per-branch governance. The fixes are also saved as a diff (/tmp/leon-voice-recorder-fixes.diff) for the branch owner to cherry-pick.

Bugs Found and Fixed

1. LeonVoiceRecorder.java — start() TOCTOU race (AudioRecord leak). `if (recording.get()) return false; ... recording.set(true)` was non-atomic: two concurrent `start()` calls could both open the mic, leaking the first `AudioRecord`. Fixed with an up-front `compareAndSet(false, true)` and `set(false)` on every early-return path.

2. LeonVoiceRecorder.java — MAX_DURATION_MS overshoot. The capture buffer was `minBufferBytes * 4` (several seconds), letting the 30 s ceiling overshoot by a large multi-chunk block. Reduced to a single `minBufferBytes` chunk so one read is short and the ceiling is tight.

Both fixes verified: stub-compiled clean; WAV header byte-for-byte correct against the canonical PCM spec; `release()` guaranteed via `try/finally`; the recording flag is now genuinely atomic. No visual/device confirmation was possible (no emulator).

Issues Found but NOT Fixed

- **LeonConversationController.submit()** — no re-entrancy guard; a late `onSpeakingStarted` from a cancelled/overlapped turn can resurrect THINKING/SPEAKING. *Reason:* no production Backend exists yet — hardening guidance, not a live bug.
- **LeonSpeechController.shutdown()** — posts TTS release onto the main Looper; if the Looper is already torn down it may never run. *Reason:* not a leak in the current app lifecycle.
- **AssetDirArtProvider.bitmapFor()** — builds new `File(overrideDir, artKey+ext)` with no canonical-path containment check; a `..` key could traverse. *Reason:* unreachable from the shipped app (keys come from fixed `LeonRig.Art` constants; packaged assets cannot contain `..`); legacy provider unused by the production puppet path.
- **LeonOverlayService** — no mid-session overlay-permission revocation watchdog (Leon stays drawn until the next entry point; 'Stop' will not remove an already-attached view). *Reason:* every documented entry point does re-check; a watchdog is a behavior change, not a bug.
- **leon_voice.py route — audio.read() buffers the whole upload before the size check** (413 bound is post-read). *Reason:* partial DoS vector mitigated by rate limiting + token auth; a true fix needs streaming-counted reads / a proxy limit — a design decision.
- **LEON_SYSTEM_PROMPT** — no explicit 'ignore instructions in user text/history' hardening. *Reason:* product/prompt decision; system-role separation already gives baseline injection resistance.

Part-by-Part Results

Part 1 — Skeletal rig & animation (rig/, anim/).

- Render-safe clamps are applied to the FINAL per-bone value after all channels combine (LeonRigBinder.java:274-279); the earlier HAND_R_RAISE compound fix is intact and locked by tests.
- World-space compounding traced across the whole arm chain: forearm-local $\leq \sim 24^\circ$ ($\leq$ ELBOW_ROTATION_LIMIT_DEG=25), world hand $\leq \sim 15.7^\circ$ — bounded by the tightest cap, so no unchecked-compound fold. WEIGHT_SHIFT does not compound with WALK_BOB (bob writes offsetY only, never rotation); breathing+posture compose through chest scale, not rotation.
- weightsFor() seams all blend smoothly with no gaps/overlaps; every vertex weight sums to 1.0 (normalized() clamps + divides, throws on non-finite); all bone/part lookups fail loudly (no silent default/zero transforms).
- **No code bugs found.** JVM tests: 136/137 pass (1 failure is environmental — missing generated asset).

Part 2 — State machine, conversation, lip-sync, voice recorder (state/, voice/).

- State machine sound: only ATTENTION is transient; update() always resolves to a non-transient target (IDLE fallback); tick() uses a monotonic clock with a 0.5 s cap; MINIMISED is sticky until restore(). No state can strand Leon.
- Lip-sync queue bounded (MAX_QUEUED=48, drops oldest); stop() leaves a valid rest state from any point; no activeElapsed/activeDuration desync.
- LeonSpeechController: stale utteranceId callbacks guarded on every path; shutdown() releases TTS; a per-utterance rejection does not disable future speech.
- **2 bugs fixed in LeonVoiceRecorder (see above).** state+lip-sync+conversation tests: 29/29 pass.

Part 3 — Rendering, overlay service, asset pipeline (render/, overlay/, asset/).

- Overlay lifecycle correct: onDestroy persists state/position to LeonPrefs and tears down the view; overlay permission re-checked at every entry point (onCreate, onStartCommand, unhide, SCREEN_ON/USER_PRESENT).
- Render loop correct: 60fps/20fps gating via wantsHighFrameRate(); SCREEN_OFF fully stops the loop (no battery drain); resume uses a fresh clock (no time-jolt).
- ProductionLeonTexture fails loudly on missing/corrupt/mismatched assets (never renders blank). Gradle generateLeonProduction task inputs/outputs complete and correctly wired.
- **No code bugs found** (one report-only traversal gap in the legacy AssetDirArtProvider). assembleDebug is environment-blocked here (AGP on dl.google.com unreachable).

Part 4 — Backend voice API (apps/api, voice branch).

- Anthropic Messages / Whisper / TTS calls match each provider's current contract; claude-sonnet-5 is a valid current model ID; OpenAI auth correctly sends ***** (an initial "I*****" sighting was a display-layer mask of real code, confirmed at byte level — not a bug).
- Every failure path returns a safe LeonVoiceError (provider bodies/keys only logged server-side, never returned — proven by a 502-no-leak test). Cost bounds

(MAX_AUDIO_BYTES/MAX_TEXT_CHARS/MAX_HISTORY_TURNS/max_tokens) enforced and sane. No blocking calls in async paths.

- `_require_app_token` is genuinely constant-time (hmac.compare_digest, equal-length, no early compare). Config aliases `anthkey` / `ANHTOPIC_APO_KEY` verified to resolve via `pydantic-settings` case-insensitive env matching. `_parse_history` enforces last-8 truncation, drops non-dict/bad-role/non-string items, caps content length.
- Router `/leon/voice-turn` registered last; no path collision; sits behind global `rate-limit/CORS/security-headers` middleware.
- **No code bugs found.** Full API suite: 589 passed / 0 failed; ruff clean; mypy clean.

Environment-Limited Verifications (stated honestly)

- Android Gradle tasks (`testDebugUnitTest`, `lintDebug`, `assembleDebug`) could not run in this sandbox — AGP 8.7.3 resolves only from `dl.google.com`, which is blocked. Substitute: compiled the identical pure-JVM sources + all 16 test classes with `javac` and ran them via JUnit 4.13.2 → 136/137 pass (the one failure is a missing generated-asset artifact, present in CI). A passing numeric test is not proof a render is visually clean — no pixels were rendered.
- Backend API fully verified: `pip install -e '[dev]'`, `alembic upgrade head` (through 0058), `pytest` → 589 passed / 0 failed (real Postgres 16, correct RLS roles), ruff clean, mypy clean on the four Leon files + `config.py`. The voice route regresses nothing.

Net result: 2 real bugs (both in the new `LeonVoiceRecorder`) found and fixed; 6 issues documented as report-only; everything else audited clean. No production behavior was changed beyond the two targeted recorder fixes.